

Auditoría de arquitectura y producto

SaaS B2B multi-tenant para couriers de última milla

Evaluación ejecutiva

El sistema tiene una propuesta de valor coherente y defendible: convertir un evento operacional —la entrega— en dos consecuencias financieras trazables —cobro al cliente vendedor y liquidación al conductor— y conciliarlas automáticamente.

La arquitectura funcional descrita cubre una parte importante del ciclo operacional. Sin embargo, antes de escalar el número de couriers, hay cuatro frentes que deben considerarse prioritarios:

1. **Blindar la determinación financiera** frente a duplicados, reintentos, cambios tardíos y cierres concurrentes.
2. **Convertir las integraciones simuladas o parciales en flujos productivos controlados**, manteniendo las aprobaciones humanas obligatorias.
3. **Centralizar controles transversales**, especialmente autenticación, autorización, ejecución de procesos automáticos y observabilidad.
4. **Construir una operación por excepciones**, donde los procesos normales sean automáticos y el usuario intervenga solamente ante discrepancias, aprobaciones o decisiones irreversibles.

No considero urgente incorporar un optimizador de rutas ni nuevas fuentes de pedidos. Para estas últimas basta, por ahora, con mantener contratos de adaptadores suficientemente desacoplados.

1. Oportunidades de mejora sobre lo ya construido

1.1. Motor entrega-dinero

P0 — Garantizar idempotencia financiera

Qué cambiar

Cada consecuencia financiera debe tener una identidad de negocio única y verificable en base de datos. Por ejemplo:

- Línea de cobro: tenant + pedido + concepto cobrable + versión de regla.
- Línea de liquidación: tenant + pedido + conductor + concepto liquidable + versión de regla.
- Conciliación: tenant + fuente + referencia externa + tipo de movimiento.
- Pago entrante o saliente: tenant + proveedor + identificador externo.

Agregar restricciones únicas en base de datos y no depender solamente de validaciones en código.

Por qué

El mismo estado final puede recibirse varias veces por:

- Notificación push duplicada.
- Sondeo de respaldo.
- Recuperación histórica.
- Reintento de un proceso automático.
- Reconexión de una cuenta.
- Respuesta tardía de una integración.

Sin idempotencia a nivel de base de datos, un reintento legítimo puede convertirse en un cobro o una liquidación duplicada.

Estado actual: no determinado.

P0 — Hacer atómica o reanudable la transición entrega → dinero

Qué cambiar

La transición que genera la línea de cobro y la línea de liquidación debe cumplir una de estas dos garantías:

- Ambas líneas se crean dentro de una única transacción consistente.
- O la operación queda persistida en un estado intermedio explícito y reanudable, de modo que un fallo nunca deje solo una de las dos líneas sin que el sistema lo detecte.

Agregar una validación automática que identifique:

- Pedido elegible sin línea de cobro.
- Pedido elegible sin línea de liquidación.
- Pedido con una sola de las dos consecuencias.
- Líneas duplicadas.
- Líneas asociadas a un estado de pedido no elegible.

Esto puede ejecutarse mediante el mecanismo actual de procesos en segundo plano, sin introducir microservicios ni un broker de mensajería.

Estado actual: no determinado.

P0 — Versionar y congelar las reglas económicas

Qué cambiar

Cada línea financiera debe conservar un snapshot de los elementos que determinaron su valor:

- Regla aplicada.
- Versión de la regla.
- Tarifa.
- Recargos o descuentos.
- Zona considerada.

- Fecha efectiva.
- Estado del pedido que disparó el cálculo.
- Incidencias consideradas.
- Resultado de elegibilidad.
- Motivo de inclusión o exclusión.

Un cambio futuro de tarifa no debe modificar retroactivamente una línea ya generada.

Por qué

Sin este snapshot, será difícil explicar por qué un pedido se cobró o liquidó de una determinada manera semanas o meses después.

Estado actual: no determinado.

P0 — Implementar ajustes posteriores sin modificar períodos cerrados

Qué agregar

Un flujo formal de ajustes para situaciones como:

- Incidencia registrada después del cierre.
- Corrección de tarifa.
- Cambio válido en la elegibilidad.
- Pago recibido y luego reversado.
- Pedido marcado erróneamente como entregado.
- Diferencia detectada por conciliación.

Los períodos cerrados y documentos emitidos no deben reescribirse. La corrección debe generar:

- Línea de ajuste positiva o negativa.
- Referencia a la línea original.
- Motivo obligatorio.
- Usuario o proceso que originó el ajuste.
- Período en el que se reconocerá.
- Nota de crédito, cuando corresponda, siempre con aprobación humana explícita.

Estado actual: no determinado.

P0 — Endurecer el cierre de períodos y liquidaciones

Qué cambiar

Agregar controles de concurrencia y estados explícitos:

- Abierto.
- En preparación.
- En conciliación.
- Listo para revisión.

- Cerrado.
- Con discrepancias.
- Ajustado.
- Facturado o pagado, según corresponda.

El cierre automático debe contar con:

- Bloqueo lógico para impedir dos ejecuciones simultáneas.
- Clave idempotente por tenant y período.
- Registro del momento exacto de corte.
- Conteo esperado y procesado de líneas.
- Resultado de la conciliación.
- Estado de ejecución visible.
- Reanudación segura después de un fallo.

Estado actual: no determinado.

P0 — Incorporar un preflight antes de aprobar facturas, notas de crédito y pagos

Qué agregar

Antes de habilitar la acción humana irreversible, mostrar una validación automática con:

- Cantidad de pedidos incluidos.
- Total bruto, descuentos, impuestos y total final.
- Líneas excluidas y motivo.
- Discrepancias pendientes.
- Incidencias que afectan cobro o liquidación.
- Datos tributarios o bancarios incompletos.
- Documentos o pagos similares ya emitidos.
- Estado de la integración.
- Disponibilidad de folios, cuando corresponda.

La aprobación sigue siendo humana. El sistema solamente prepara, verifica y bloquea acciones evidentemente inconsistentes.

P1 — Crear una vista unificada de trazabilidad financiera

Qué agregar

Desde cualquier pedido debería ser posible navegar a:

Pedido → evento final → regla aplicada → línea de cobro → período → factura → pago recibido → conciliación

Y, en paralelo:

Pedido → asignación → conductor → regla aplicada → línea de liquidación → liquidación → pago saliente → confirmación

También debe funcionar la navegación inversa: desde una factura o liquidación hasta los pedidos que la componen.

Por qué

Esta vista reduce sustancialmente el tiempo de soporte, conciliación y explicación a clientes y conductores.

P1 — Convertir la conciliación en una bandeja de excepciones

Qué mejorar

En vez de mostrar solamente discrepancias técnicas, clasificarlas con estados y acciones:

- Nueva.
- En análisis.
- Esperando información externa.
- Resuelta automáticamente.
- Resuelta manualmente.
- Aceptada como diferencia justificada.
- Requiere ajuste.
- Bloquea facturación.
- Bloquea pago.
- No bloqueante.

Cada discrepancia debe tener:

- Categoría.
 - Monto afectado.
 - Origen de los datos comparados.
 - Explicación legible.
 - Acción sugerida.
 - Responsable.
 - Fecha límite.
 - Historial de resolución.
-

1.2. Integración con la fuente externa

P0 — Unificar deduplicación, recuperación y actualización de pedidos

Qué cambiar

Las notificaciones push, el sondeo de respaldo y la recuperación histórica deben entrar por una misma lógica de normalización e idempotencia.

Cada actualización externa debería registrar:

- Cuenta conectada de origen.

- Identificador externo.
- Fecha del evento externo.
- Fecha de recepción.
- Estado original.
- Estado interno traducido.
- Versión del traductor.
- Canal de recepción: push, polling o recuperación.
- Resultado del procesamiento.

Por qué

Esto evita que tres mecanismos de sincronización produzcan tres interpretaciones diferentes del mismo evento.

P1 — Mostrar la salud por cuenta conectada, no solo por cliente vendedor

Un cliente vendedor puede conectar hasta tres cuentas. La pantalla de salud debería distinguir:

- Cuenta activa.
 - Credenciales próximas a vencer.
 - Última notificación recibida.
 - Último sondeo exitoso.
 - Último pedido sincronizado.
 - Diferencia entre la hora externa y la hora interna.
 - Recuperación histórica en curso.
 - Errores consecutivos.
 - Acción recomendada.
-

P1 — Versionar la traducción de estados externos

Qué agregar

Mantener un catálogo versionado de estados externos y su traducción al modelo interno.

Cuando aparezca un estado desconocido:

- No interpretarlo silenciosamente como uno conocido.
- Mantener el valor original.
- Marcarlo como pendiente de clasificación.
- Evitar que genere consecuencias financieras hasta que se determine su significado.
- Alertar al equipo responsable.

Estado actual: no determinado.

1.3. Operación de pedidos

P1 — Diferenciar visualmente la autoridad del estado y la evidencia

El producto ya distingue correctamente entre evidencia informativa y evidencia probatoria. Esta diferencia debe ser inequívoca en la interfaz.

Para cada pedido se debería mostrar:

- Quién tiene autoridad para declarar la entrega.
- Origen del estado final.
- Evidencia informativa disponible.
- Evidencia autoritativa disponible.
- Si la evidencia puede o no modificar el estado.
- Si una incidencia afecta cobro, liquidación o ambos.

No se deben fusionar conceptualmente los dos tipos de evidencia.

P1 — Mejorar la explicabilidad de la asignación automática

La heurística simple puede mostrar por qué seleccionó a un conductor:

- Afinidad con la zona.
- Carga activa.
- Turno o disponibilidad.
- Restricciones aplicadas.
- Conductores descartados y motivo.

Agregar:

- Previsualización antes de asignación masiva.
- Capacidad de anulación manual.
- Registro de asignación automática versus manual.
- Métricas de reasignaciones y anulaciones.

Esto mejora confianza sin convertir la funcionalidad en optimización de rutas.

P1 — Controlar la calidad de geocodificación

Agregar una clasificación del resultado:

- Exacto.
- Aproximado.
- Centro de calle.
- Centro de comuna o zona.
- No encontrado.
- Corregido manualmente.

También:

- Caché por dirección normalizada.
- Corrección manual persistente.
- Evitar geocodificar reiteradamente la misma dirección.
- Bloquear o advertir el uso de coordenadas de baja confianza para la geocerca probatoria.

Estado actual de confianza y corrección manual: no determinado.

1.4. UX de aprobación y operación financiera

P1 — Aprobación por lotes con acción humana explícita

Se pueden reducir clics sin automatizar la decisión irreversible.

Por ejemplo:

- Seleccionar varios períodos o liquidaciones preparados.
- Revisar un resumen consolidado.
- Confirmar explícitamente la emisión o el pago.
- Exigir motivo en excepciones.
- Aplicar autenticación reforzada para montos altos.
- Generar un registro de aprobación por cada elemento.

La selección masiva no debe transformarse en aprobación automática.

P1 — Separar claramente preparación, aprobación y ejecución

Para facturas, notas de crédito y pagos salientes:

1. Preparación automática.
2. Validación automática.
3. Revisión humana.
4. Aprobación explícita.
5. Envío al proveedor.
6. Confirmación del proveedor.
7. Conciliación.
8. Resolución de excepciones.

Esto evita estados ambiguos como “pagado” cuando solamente se envió una solicitud de transferencia.

2. Funcionalidades faltantes para un flujo real de punta a punta

2.1. Envío real de correos electrónicos — P0

Esta brecha ya está identificada.

Qué agregar

- Proveedor de correo transaccional.
- Plantillas versionadas.
- Configuración de remitente y dominios.
- Registro de cada intento.
- Reintentos controlados.
- Estados de entrega, rebote y rechazo.
- Preferencias de destinatarios por tenant.
- Escalamiento si el correo crítico no pudo entregarse.
- Enlaces seguros que no incluyan secretos ni tokens permanentes.

Primeros casos obligatorios

- Conexión externa caída.
- Credenciales que requieren reconexión.
- Incidencia crítica sin gestionar.
- Período listo para revisión.
- Discrepancia que bloquea facturación.
- Liquidación lista para aprobación.
- Factura rechazada por el proveedor u organismo fiscalizador.
- Pago saliente fallido.
- Folios próximos a agotarse.
- Cuenta por cobrar vencida.

El centro de avisos interno debe mantenerse; el correo es un canal adicional, no su reemplazo.

2.2. Facturación electrónica productiva — P0

Actualmente no existe emisión real activa. Hay un adaptador simulado y un segundo adaptador validado técnicamente pero no conectado.

Qué falta

- Seleccionar el proveedor productivo principal.
- Conectar el adaptador elegido al flujo real.
- Gestionar credenciales productivas cifradas.
- Implementar validación previa de datos tributarios.
- Implementar emisión real después de la aprobación humana.
- Obtener y persistir identificadores y respuestas del proveedor.

- Procesar aceptación, rechazo, observaciones y estados intermedios.
- Entregar representación del documento al cliente.
- Implementar nota de crédito real con aprobación humana.
- Verificar disponibilidad y consumo de folios.
- Definir reintentos que no dupliquen documentos.
- Implementar reconciliación entre solicitud interna y documento realmente emitido.
- Agregar un procedimiento explícito de activación de sandbox a producción por tenant.

Decisión de negocio requerida

Elegir si:

- El adaptador técnicamente validado será el proveedor principal.
- El adaptador actual tendrá capacidad productiva.
- Se mantendrán ambos con estrategia de respaldo.
- Cada courier podrá elegir proveedor.

No debe desarrollarse la activación productiva completa antes de resolver esta decisión.

2.3. Confirmación instantánea de pagos salientes — P0/P1

La brecha ya está identificada: hoy se confirma mediante polling y el webhook está parcialmente definido.

Qué agregar

- Endpoint receptor.
- Verificación de firma.
- Validación temporal contra reenvíos.
- Idempotencia por identificador del proveedor.
- Registro del payload sanitizado.
- Traducción de estados externos.
- Actualización de la transferencia.
- Disparo inmediato de conciliación.
- Manejo de estados desconocidos.
- Métricas y alertas de webhooks rechazados.

El polling debe mantenerse como respaldo ante webhooks perdidos.

Dependencia externa: el proveedor debe soportar notificaciones confiables y documentadas.

2.4. Medio de pago para la suscripción del courier — P0 comercial

El sistema genera períodos mensuales de suscripción, pero no dispone de un mecanismo de cobro.

Qué agregar

- Proveedor de pago.

- Asociación entre courier, plan, período y cobro.
- Intento de cobro.
- Confirmación y conciliación.
- Reintentos.
- Estado de morosidad.
- Historial.
- Comprobantes.
- Actualización del plan.
- Cancelación.
- Reembolsos o ajustes, cuando correspondan.
- Manejo de pagos manuales, si el negocio los permite.

Decisiones de negocio requeridas

- Cobro automático o pago iniciado por el cliente.
- Transferencia, tarjeta, débito u otros medios.
- Período de gracia.
- Política de suspensión.
- Qué funcionalidades se restringen por mora.
- Política de prorrateo.
- Tratamiento de cambios de plan.
- Tratamiento tributario de la suscripción.

La suspensión por mora no debería bloquear el acceso a información financiera histórica ni impedir completar obligaciones pendientes sin una política de negocio explícita.

2.5. Segundo proveedor de conciliación bancaria — P1 condicionado

Esta brecha ya está identificada, pero no es necesariamente un bloqueo técnico para operar de punta a punta si el proveedor actual cubre a los primeros clientes.

Qué hacer ahora

Preparar un contrato interno común para:

- Cuentas.
- Movimientos.
- Referencias.
- Webhooks.
- Estados.
- Errores.
- Paginación.
- Recuperación histórica.
- Salud de conexión.

Decisión de negocio requerida

Determinar si el segundo proveedor es necesario por:

- Cobertura bancaria.
- Costos.
- Redundancia.
- Exigencias comerciales.
- Riesgo de dependencia.
- Clientes que no pueden operar con el proveedor actual.

No debe implementarse solo por simetría técnica.

2.6. Evento definido pero nunca publicado — P0 de coherencia

La brecha ya está identificada.

Acción necesaria

Elegir una de dos alternativas:

1. Implementar el punto exacto que produce el evento, sus consumidores y sus pruebas.
2. Retirar el evento, sus manejadores no utilizados y toda documentación que describa ese flujo.

Además:

- Crear una prueba de contrato que verifique que cada evento documentado tiene un productor real.
- Crear una prueba que detecte consumidores registrados para eventos que nunca pueden generarse.
- Mantener un catálogo de eventos internos efectivo, no aspiracional.

No debe permanecer como flujo “documentado” algo que el sistema no ejecuta.

2.7. Monitoreo real de producción — P0

La brecha está confirmada.

Qué agregar

- Captura centralizada de excepciones.
- Identificador de correlación por solicitud, pedido y proceso financiero.
- Métricas de procesos automáticos.
- Alertas por ejecuciones fallidas.
- Registro de duración.
- Última ejecución exitosa.
- Cantidad de tenants procesados.
- Cantidad de elementos procesados, omitidos y fallidos.
- Alertas por acumulación de pendientes.
- Tablero de salud de integraciones.

- Redacción automática de secretos y datos sensibles.

Métricas mínimas del negocio

- Pedidos finales sin línea financiera.
 - Líneas duplicadas detectadas.
 - Períodos que no cerraron.
 - Conciliaciones pendientes.
 - Documentos rechazados.
 - Pagos enviados sin confirmación.
 - Conexiones externas caídas.
 - Recuperaciones históricas detenidas.
 - Webhooks fallidos.
 - Correos críticos no entregados.
-

3. Candidatos a simplificar, consolidar o retirar

3.1. Centralizar autenticación y autorización sin obligar a un único mecanismo de acceso

Los cuatro mecanismos no son necesariamente redundantes:

- Sesión web.
- Bearer token móvil.
- Cookie del panel de plataforma.
- API key para integradores.

El problema es que cada área implementa su protección de forma independiente.

Qué consolidar

Crear un núcleo compartido de seguridad que resuelva:

- Validación de credenciales.
- Carga de identidad.
- Resolución de tenant.
- Roles y permisos.
- Revocación.
- Expiración.
- Auditoría.
- Respuestas de acceso denegado.
- Reglas de sesión.
- Autenticación reforzada para acciones financieras.
- Políticas específicas por canal.

Cada canal puede conservar su credencial apropiada, pero no su propia interpretación independiente de permisos.

Qué retirar

- Validaciones copiadas en controladores o endpoints.
 - Lectura manual repetida de cookies o headers.
 - Comprobaciones de rol distintas para la misma acción.
 - Resolución ad hoc del tenant.
-

3.2. Consolidar la ejecución de procesos automáticos

Existe un número considerable de procesos periódicos. El riesgo es que cada uno tenga políticas distintas de reintento, bloqueo y observabilidad.

Qué consolidar

Un framework interno común, dentro de la arquitectura actual, con:

- Registro de cada tipo de trabajo.
- Clave idempotente.
- Bloqueo de ejecución.
- Política de reintento.
- Timeout.
- Estado de ejecución.
- Tenant procesado.
- Heartbeat.
- Resultado resumido.
- Alertas.
- Reanudación.
- Historial.

Esto no exige microservicios ni una cola propia.

Qué retirar

- Cron jobs o temporizadores sin registro central.
 - Reintentos infinitos.
 - Procesos que fallen silenciosamente.
 - Lógicas diferentes para evitar concurrencia.
-

3.3. Unificar contratos de adaptadores externos

Crear contratos consistentes para:

- Autenticación.
- Salud.
- Errores recuperables y definitivos.
- Idempotencia.
- Reintentos.
- Rate limits.

- Estado sandbox/productivo.
- Auditoría.
- Sanitización de logs.
- Activación y desactivación.

Aplicarlo a:

- Fuente logística.
- Facturación electrónica.
- Conciliación bancaria.
- Transferencias.
- Geocodificación.

Esto facilita agregar proveedores sin introducir nuevas arquitecturas.

3.4. Mantener un solo modelo canónico de estados internos

Los estados externos deben traducirse a un modelo interno único. No debería existir lógica financiera dependiente directamente de nombres o códigos del proveedor externo.

Retirar o evitar

- Condiciones financieras basadas en strings externos.
- Traducciones duplicadas en distintos módulos.
- Estados internos creados solo para reflejar pequeñas diferencias del proveedor.

Conservar el estado original externo para auditoría, pero usar el canónico para el comportamiento interno.

3.5. Consolidar el almacenamiento de evidencias sin mezclar su autoridad

Puede existir una infraestructura común para:

- Almacenamiento.
- Cifrado.
- Acceso.
- Retención.
- Hash.
- Metadatos.
- Auditoría.

Pero cada evidencia debe conservar atributos explícitos:

- Informativa o autoritativa.
- Actor que la capturó.
- Origen.
- Momento.

- Coordinadas.
- Pedido.
- Capacidad de afectar o no el estado.

No se recomienda retirar la separación conceptual existente.

3.6. Centralizar notificaciones y entregas salientes

Crear un único módulo para:

- Avisos internos.
- Correos.
- Notificaciones a sistemas del vendedor.
- Reintentos.
- Plantillas.
- Entrega.
- Fallos.
- Preferencias.
- Historial.

Una misma situación de negocio —por ejemplo, conexión caída— debería generar un evento interno común y luego decidir los canales configurados.

No debe existir lógica de correo o webhook copiada dentro de cada proceso automático.

3.7. Retirar código y documentación aspiracional

Además del evento no publicado:

- Eliminar endpoints incompletos que parezcan productivos.
 - Marcar explícitamente adaptadores sandbox.
 - Evitar botones visibles que no completen la operación.
 - Retirar flags obsoletos.
 - Diferenciar “definido”, “parcial”, “simulado” y “productivo”.
 - Generar documentación desde contratos o pruebas cuando sea posible.
-

4. Riesgos no cubiertos

4.1. Riesgos financieros

Duplicación de cobros o liquidaciones

La combinación push + polling + recuperación histórica hace este riesgo especialmente importante.

Mitigación: idempotencia en base de datos, claves externas, pruebas de reintento y reconciliación de integridad.

Desalineación entre cobro y liquidación

Un fallo parcial podría crear una consecuencia financiera sin la otra.

Mitigación: transacción única o estado reanudable y verificación diaria de integridad.

Cambios retroactivos en reglas

Estado actual: no determinado.

Mitigación: versionado y snapshot de reglas y tarifas.

Modificación de períodos cerrados

Estado actual: no determinado.

Mitigación: inmutabilidad y líneas de ajuste.

Redondeo, precisión monetaria e impuestos

Estado actual: no determinado.

Debe verificarse que:

- No se utilicen números de punto flotante.
- Existan reglas explícitas de redondeo.
- Los totales se recalculen y validen.
- El valor de cada línea pueda reproducirse.

Acciones financieras sin segregación suficiente

Existen roles diferenciados, pero no está determinado si una persona puede preparar y aprobar la misma operación.

Debe definirse si se requiere:

- Regla maker-checker.
- Doble aprobación por monto.
- Límites por rol.
- Autenticación reforzada.
- Prohibición de aprobar cambios propios.

Decisión de negocio y gobernanza requerida.

4.2. Riesgos multi-tenant

RLS es una decisión correcta, pero debe comprobarse de forma continua.

No determinado

- Si todas las tablas con datos de negocio tienen política RLS.
- Si tablas nuevas pueden desplegarse sin política.
- Si procesos automáticos establecen correctamente el contexto de tenant.
- Si existen usuarios de base de datos con capacidad de omitir RLS.
- Cómo se controla el acceso del administrador de plataforma a datos del courier.
- Si archivos y evidencias aplican aislamiento equivalente fuera de la base de datos.

Mitigaciones

- Pruebas automáticas de aislamiento.
- Migraciones que fallen cuando una tabla multi-tenant no tenga RLS.
- Contexto obligatorio de tenant en procesos automáticos.
- Separar roles de base de datos.
- Auditar accesos administrativos.
- Incorporar tenant en las claves de objetos almacenados y validar acceso antes de entregar URLs firmadas.

4.3. Riesgos de autenticación y autorización

La ausencia de middleware central aumenta la probabilidad de:

- Endpoint sin protección.
- Diferencias entre permisos equivalentes.
- Sesiones que expiran de manera distinta.
- Tenant resuelto desde una fuente manipulable.
- Falta de auditoría uniforme.
- Nuevas rutas que olviden una validación.

Controles que deben verificarse; estado actual no determinado

- CSRF en sesiones web.
- Cookies seguras, HttpOnly y políticas SameSite.
- Rotación y revocación de tokens móviles.
- Alcances de API keys.
- Rotación de API keys.
- Rate limiting.
- MFA para administradores y aprobadores financieros.
- Protección contra fuerza bruta.
- Invalidación de sesiones al cambiar roles.
- Separación estricta de la sesión del administrador de plataforma.

Para API keys utilizadas únicamente para validación, es preferible almacenar un hash irreversible y mostrar la clave completa solo al crearla. Los tokens que deban reutilizarse contra terceros deben mantenerse cifrados.

4.4. Riesgos de webhooks e integraciones

Para cada webhook entrante debe existir:

- Firma.
- Timestamp.
- Protección contra replay.
- Idempotencia.
- Límite de tamaño.
- Validación de esquema.
- Registro sanitizado.
- Respuesta rápida.
- Procesamiento reanudable.
- Métrica de rechazo.

El webhook bancario entrante ya está firmado, pero el resto de estos controles es **no determinado**.

Para las notificaciones salientes a sistemas del vendedor:

- Firmar solicitudes.
- Incluir identificador único.
- Mantener historial de intentos.
- Reintentar con límites.
- Permitir reproceso manual.
- Evitar enviar datos personales innecesarios.
- Versionar el contrato.

Estado actual: no determinado.

4.5. Falta de observabilidad

La ausencia de una herramienta de monitoreo de errores es una brecha crítica confirmada.

Sin ella, pueden pasar inadvertidos:

- Cierres que no se ejecutan.
- Liquidaciones parciales.
- Credenciales que dejaron de refrescarse.
- Rechazos del proveedor tributario.
- Recuperaciones históricas detenidas.
- Webhooks fallidos.
- Diferencias financieras crecientes.

Los logs por sí solos no son suficientes. Se requieren errores, métricas, alertas y visibilidad de los procesos de negocio.

4.6. Respaldo y recuperación

No determinado

- Estrategia de backups.
- Pruebas de restauración.
- Punto objetivo de recuperación.
- Tiempo objetivo de recuperación.
- Recuperación de archivos y evidencias.
- Procedimiento frente a corrupción de datos.
- Recuperación de credenciales cifradas.
- Continuidad ante indisponibilidad del proveedor cloud.

Debe ejecutarse periódicamente una restauración real en un ambiente aislado. Tener backups sin probar restauración no constituye una estrategia de recuperación.

4.7. Privacidad e integridad de evidencias

Las fotos y geolocalización pueden contener datos personales.

No determinado

- Política de retención.
- Quién puede descargar evidencia.
- Si se registra cada acceso.
- Cuándo se elimina.
- Cómo se atienden solicitudes de eliminación cuando existe una obligación de conservación.
- Si se elimina metadata innecesaria de las imágenes.
- Si se verifica integridad del archivo.

Para evidencia autoritativa se recomienda almacenar:

- Hash del archivo.
- Timestamp del servidor.
- Identificador del conductor.
- Pedido.
- Coordenadas.
- Precisión de ubicación.
- Metadata de captura necesaria.
- Historial de acceso.
- Indicador de modificación o reemplazo.

No debe permitirse reemplazar silenciosamente una evidencia probatoria.

4.8. Dependencia de proveedores

Riesgos presentes:

- Un único proveedor bancario.
- Adaptador tributario productivo todavía no activado.
- Confirmación de transferencias dependiente de polling.
- Fuente logística obligatoria como origen principal.
- Servicio externo de geocodificación.

Debe existir para cada integración:

- Estado degradado.
- Procedimiento de reconexión.
- Reintentos.
- Límites.
- Circuito de desactivación.
- Recuperación histórica.
- Operación manual excepcional.
- Alertas.
- Métricas de disponibilidad.

No es necesario agregar inmediatamente proveedores alternativos para todos los casos; sí es necesario evitar que una caída produzca datos financieros silenciosamente incompletos.

4.9. Procesamiento concurrente y capacidad

Los cierres diarios y las liquidaciones pueden concentrar carga en horarios similares para muchos tenants.

Estado actual: no determinado.

Debe probarse:

- Cierre simultáneo de múltiples tenants.
- Recuperación histórica mientras se ejecuta el cierre.
- Llegada tardía de estados durante conciliación.
- Reintentos concurrentes.
- Volumen alto de pedidos de un solo courier.
- Bloqueos de base de datos.
- Índices por tenant, estado, fecha, período e identificadores externos.

Los procesos deberían distribuirse de forma controlada mediante el ejecutor actual, sin introducir microservicios.

4.10. Conectividad del conductor

No determinado

No se describe el comportamiento de la aplicación móvil cuando el conductor pierde conectividad.

Debe clarificarse:

- Si puede consultar manifiestos sin conexión.
- Si puede capturar evidencia temporalmente.
- Cómo se evita duplicar entregas al sincronizar.
- Qué timestamp se considera autoritativo.
- Cómo se tratan coordenadas capturadas sin conectividad.
- Qué ocurre si la asignación cambia antes de sincronizar.

No debe asumirse que esta capacidad existe.

4.11. Fechas, cortes y zonas horarias

No determinado

El cierre diario, los horarios de corte y los eventos externos deben utilizar:

- Zona horaria explícita por tenant o una política única definida.
- Instante de corte persistido.
- Fecha contable separada del timestamp técnico cuando corresponda.
- Reglas consistentes para eventos tardíos.

Esto evita que un pedido cambie de período por diferencias entre la hora del proveedor, el servidor y el courier.

5. Propuesta de secuencia de trabajo

Etapas 0 — Establecer invariantes del núcleo

Antes de ampliar funcionalidades, documentar y convertir en pruebas automáticas las reglas que nunca pueden romperse:

- Un pedido no genera dos líneas equivalentes.
- Toda línea pertenece a un tenant.
- Una línea cerrada no se modifica.
- Una factura no se emite sin aprobación humana.
- Una nota de crédito no se emite sin aprobación humana.
- Un pago saliente no se ejecuta sin aprobación humana.
- Una recuperación histórica no duplica dinero.
- Un reintento produce el mismo resultado que una ejecución única.
- Un estado externo desconocido no genera consecuencias financieras.
- Toda acción financiera queda auditada.

Esta etapa es estructural y condiciona todas las siguientes.

Quick wins

QW1 — Resolver el evento inexistente

Implementarlo completamente o retirarlo junto con su documentación.

QW2 — Incorporar monitoreo de errores

Instrumentar primero:

- Ingesta de pedidos.
- Generación de líneas.
- Cierre de períodos.
- Generación de liquidaciones.
- Facturación.
- Transferencias.
- Conciliación.
- Refresco de credenciales.

QW3 — Agregar telemetría a todos los procesos automáticos

Última ejecución, resultado, duración, elementos procesados y alerta por fallo.

QW4 — Implementar correo para alertas críticas

Comenzar por conexión caída, incidencia crítica, documento rechazado y pago fallido.

QW5 — Completar el endpoint de confirmación de transferencias

Mantener polling como respaldo.

QW6 — Añadir verificaciones de integridad financiera

Consultas o procesos que detecten:

- Pedidos finales sin líneas.
- Líneas sin pedido.
- Líneas duplicadas.
- Diferencias entre cobro y liquidación.
- Documentos o pagos sin referencia interna.

QW7 — Identificar claramente sandbox y producción

Mostrarlo en la interfaz administrativa y evitar que una operación simulada parezca una operación real.

Trabajo estructural prioritario

Fase 1 — Blindaje del motor entrega-dinero

Orden recomendado:

1. Idempotencia y restricciones únicas.
2. Transacción o estado reanudable entrega-dinero.
3. Versionado de reglas y tarifas.
4. Inmutabilidad de períodos cerrados.
5. Flujo de ajustes.
6. Preflight de facturas y pagos.
7. Trazabilidad completa.
8. Bandeja de excepciones.

Esta fase debe preceder a la activación masiva de facturación y pagos reales.

Fase 2 — Seguridad transversal

1. Núcleo compartido de autenticación y autorización.
2. Migración progresiva de cada área al middleware común.
3. Pruebas de permisos.
4. Pruebas automáticas de RLS.
5. MFA o autenticación reforzada para acciones críticas.
6. Rotación y revocación de credenciales.
7. Revisión del acceso del administrador de plataforma.
8. Endurecimiento de webhooks y API keys.

No es necesario cambiar simultáneamente los cuatro mecanismos de acceso. Debe centralizarse primero su validación y modelo de permisos.

Fase 3 — Operación productiva completa

1. Correo transaccional.
 2. Facturación electrónica productiva.
 3. Nota de crédito productiva.
 4. Confirmación instantánea de transferencias.
 5. Conciliación inmediata y polling de respaldo.
 6. Activación controlada de pagos reales.
 7. Medio de pago de la suscripción SaaS.
 8. Segundo proveedor bancario, únicamente si la decisión comercial lo justifica.
-

Fase 4 — Operación por excepciones y UX

1. Bandeja unificada de discrepancias.
2. Preflight legible.
3. Aprobación explícita por lotes.
4. Navegación pedido-dinero.

5. Salud de integraciones por cuenta.
6. Explicabilidad de asignaciones.
7. Calidad de geocodificación.
8. Seguimiento de notificaciones y webhooks.

Fase 5 — Escalabilidad y preparación para futuras fuentes

1. Contratos comunes de adaptadores.
2. Catálogo canónico de estados.
3. Pruebas de carga de cierres y recuperaciones.
4. Optimización de índices.
5. Pruebas de restauración.
6. Procedimientos de continuidad.
7. Versionado de APIs y webhooks.
8. Documentación efectiva de integraciones.

Esta fase prepara el terreno para nuevas fuentes de pedidos, pero no implica construirlas todavía.

Decisiones de negocio que bloquean o condicionan trabajo

Decisión	Trabajo afectado
Proveedor principal de facturación electrónica	Activación de documentos reales
Estrategia con uno o dos proveedores tributarios	Diseño de fallback y configuración por tenant
Medio de pago de la suscripción SaaS	Cobro a couriers, morosidad y suspensión
Política de gracia y suspensión	Gestión de suscripciones
Necesidad comercial de un segundo proveedor bancario	Prioridad de la segunda integración
Activación de transferencias reales global o por tenant	Flujo de onboarding y controles de riesgo
Segregación de funciones y límites de aprobación	Roles, maker-checker y MFA
Política de retención de fotos y geolocalización	Evidencias, almacenamiento y privacidad
Alcance de acceso del administrador de plataforma	Autorización y auditoría cross-tenant
Política de operación móvil sin conectividad	Diseño de sincronización y evidencia
SLA de alertas e incidencias	Correo, escalamiento y monitoreo
Política horaria y fecha contable	Cierres, cortes y eventos tardíos

Prioridad consolidada

P0 — Antes de escalar

- Idempotencia financiera.
- Consistencia entrega-cobro-liquidación.
- Inmutabilidad y ajustes.
- Monitoreo de errores y procesos.
- Pruebas de RLS.
- Centralización progresiva de autenticación y autorización.
- Resolución del evento nunca publicado.
- Facturación electrónica productiva.
- Confirmación robusta de pagos salientes.
- Correo para alertas críticas.
- Estrategia de backup y restauración.
- Preflight para acciones financieras.

P1 — Para una operación completa y eficiente

- Bandeja de excepciones.
- Trazabilidad pedido-dinero.
- Medio de pago de la suscripción.
- Salud detallada de integraciones.
- Contratos comunes de adaptadores.
- Versionado de estados externos.
- Calidad de geocodificación.
- Aprobaciones por lotes.
- Integridad y retención de evidencia.
- Segundo proveedor bancario, si existe necesidad comercial.

P2 — Preparación de crecimiento

- Optimización de performance basada en mediciones.
- Extensibilidad para futuras fuentes.
- Mejora de explicabilidad de la asignación.
- Capacidades móviles con conectividad intermitente, si el negocio lo requiere.
- Estrategias adicionales de resiliencia por proveedor.

Conclusión

El mayor riesgo del sistema no está en la ausencia de más funcionalidades operacionales, sino en que los mismos mecanismos que le dan resiliencia —push, polling, recuperación histórica, trabajos periódicos y múltiples integraciones— pueden producir inconsistencias financieras si no están unidos por garantías fuertes de idempotencia, versionado, inmutabilidad y trazabilidad.

La prioridad correcta es blindar primero el circuito:

entrega autoritativa → elegibilidad → línea de cobro y liquidación → período → aprobación humana → ejecución externa → confirmación → conciliación.

Una vez protegido ese circuito, deben activarse las integraciones productivas, centralizarse los controles transversales y convertir la operación diaria en una gestión por excepciones. El optimizador de rutas y las fuentes adicionales pueden permanecer pospuestos sin perjudicar la propuesta de valor actual.